

Sauvegarde chiffrée des secrets — méthode et explications

Résumé en une phrase : les secrets du projet sont rangés dans une archive chiffrée avec une phrase de passe que **vous seul** connaissez, puis envoyés sur Proton Drive ; sans la phrase, l'archive est illisible pour tout le monde, y compris pour vous.

hprzeta — Projet Riemann_Lab — 04/10/2026 — script concerné : `zeta_backup_horsgit.sh` (alias `zeta-backup-horsgit`), jeu 6.

1. Pourquoi une phrase de passe ?

Proton Drive chiffre déjà vos fichiers de bout en bout. Mais le jeton qui permet à PC1 et à PC3 d'écrire dans Proton (rclone) est lui-même stocké sur ces machines. Deux situations dangereuses existent :

- un appareil du cluster est compromis et le jeton rclone est volé ;
- le compte Proton est ouvert par quelqu'un d'autre.

Dans les deux cas, un fichier non chiffré serait lisible. Avec la phrase de passe, une **deuxième couche** protège les secrets : l'archive n'est qu'une suite d'octets illisibles sans elle.

- **Chiffrement de Proton** : protège le contenu contre Proton lui-même. Contrôlé par Proton.
- **Phrase de passe gpg (cette méthode)** : protège les secrets même si le compte ou un jeton fuit. Contrôlée par vous seul.

En usage normal, vous ne voyez cette phrase qu'au moment de l'envoi. Elle ne sert vraiment qu'en cas de catastrophe (perte de PC1) ou de fuite.

2. Ce que contient l'archive

L'archive porte un nom daté : `secrets_AAAAMMJJ.tar.gz.gpg`. Elle regroupe :

- **Le dossier `secrets_local`**, pris dans `~/riemann_handoff` : environ 180 Mo avant compression, surtout des archives zip.
- **Les secrets du projet ignorés par git** : au moment de l'écriture, 35 fichiers pour environ 11 Mo (fichier de configuration MCP contenant un jeton, captures d'écran WireGuard, archive de la box, deux fichiers d'inventaire matériel).

Volontairement absents : le dossier `~/ssh` (clés SSH privées) et la configuration rclone. Ils ne sont pas dans l'archive tant que vous ne l'avez pas décidé.

3. Faire la sauvegarde

Le jeu 6 est **manuel** : il demande votre phrase, donc le cron de nuit ne peut pas le lancer.

```
zeta-backup-horsgit
# verifier que l'en-tete affiche [ENVOI REEL] (c'est le mode par default)
# taper 6 pour lancer le jeu des secrets
# saisir la phrase de passe, puis la saisir une 2e fois (confirmation)
```

Attention à la touche d : elle bascule vers la **simulation**. Le menu démarre déjà en ENVOI RÉEL ; ne tapez d que pour essayer sans rien envoyer.

Le déroulement :

1. le script construit la liste des secrets du projet ignorés par git ;
2. il compresse secrets_local et ces fichiers, et chiffre le tout avec gpg (algorithme AES256) ;
3. il envoie l'archive sur Proton, dans le dossier hors_git/secrets_chiffres ;
4. il efface aussitôt la copie temporaire locale : aucune archive reste sur PC1 ;
5. il applique la rotation (voir §4).

En mode simulation (après avoir tapé d, ou avec l'option --dry), rien n'est créé ni envoyé : le script annonce seulement « secrets_local + N fichiers secrets du projet ».

4. Où va l'archive, et la rotation

Chemin sur Proton : protondrive:hprzeta/Riemann_Lab/hors_git/secrets_chiffres/.

Chaque jour d'envoi crée un **nouveau fichier daté** (rclone copy n'efface rien). Comme l'archive pèse plus de 180 Mo et que Proton offre 2 Gio, les archives s'accumuleraient vite. La **rotation** garde donc les **2 archives les plus récentes** et supprime les plus anciennes.

Situation après un envoi	Ce que fait la rotation
1 ou 2 archives sur Proton	rien
3 archives ou plus	supprime les plus anciennes, jusqu'à n'en garder que 2
Nouvel envoi en erreur	rotation sautée, anciennes archives conservées
Nouvel envoi introuvable sur Proton	rotation sautée
Deux envois le même jour	le second remplace le premier (même nom)

Garde-fous : la rotation ne touche que les fichiers nommés exactement secrets_AAAAM-MJJ.tar.gz.gpg dans ce seul dossier. Tout autre fichier est ignoré. Elle ne s'exécute qu'une fois le nouvel envoi confirmé présent sur Proton. Le nombre conservé se règle dans le script (variable KEEP_SECRETS, valeur 2).

5. Restaurer (et vérifier que vous savez le faire)

Faites ce test une fois, juste après le premier envoi, tant que tout est encore sur PC1.

```
mkdir -p ~/restauration_secrets
cd ~/restauration_secrets
rclone copy protondrive:hprzeta/Riemann_Lab/hors_git/secrets_chiffres/secrets_AAAAMMJJ.tar.gz.gpg .
gpg -d secrets_AAAAMMJJ.tar.gz.gpg | tar -tz | head -20
```

La dernière commande demande la phrase puis **liste** le contenu sans rien extraire. Si la liste s'affiche, la phrase est bonne et l'archive est saine.

Pour extraire réellement (après une perte, par exemple) :

```
gpg -d secrets_AAAAMMJJ.tar.gz.gpg | tar -xz
```

L'archive recrée le dossier `secrets_local` et les fichiers du projet, avec leurs chemins relatifs. Recopiez-les à leur place d'origine, puis supprimez le dossier de restauration : il contient des secrets **en clair**.

```
rm -r ~/restauration_secrets
```

6. Règles pour la phrase de passe

À faire :

- La choisir longue : 4 ou 5 mots sans rapport entre eux.
- La garder dans un gestionnaire de mots de passe **ou** sur papier, hors de PC1.
- Vérifier une fois la restauration (§5).

À ne pas faire :

- La mettre dans Proton, dans git, dans un script ou dans un message.
- La garder seulement sur PC1 : si PC1 est perdu, l'archive devient inutile.
- Réutiliser le mot de passe de votre compte Proton.

7. Cas particuliers

Phrase oubliée. L'archive est irrécupérable : ni gpg, ni Proton, ni personne ne peut la rouvrir. Tant que PC1 existe, ce n'est pas grave : relancez le jeu 6 avec une nouvelle phrase. Le vrai danger est de perdre PC1 **et** la phrase en même temps.

Phrase compromise. Relancez le jeu 6 avec une nouvelle phrase. Attention : la rotation garde l'ancienne archive (celle de l'ancienne phrase) jusqu'au prochain envoi. Supprimez-la à la main sur Proton si vous craignez qu'elle soit déjà entre de mauvaises mains.

Changer de phrase. Même démarche : un nouvel envoi avec la nouvelle phrase. Chaque archive est indépendante, avec sa propre phrase.

Quota. Au moment de l'écriture, 1,63 Gio sont libres sur Proton. Deux archives de 190 Mo environ occupent moins de 400 Mo. Vérifiez la taille réelle après le premier envoi.

8. Place de ce jeu dans la sauvegarde « hors git »

Jeu	Contenu	Envoi
1	dossier md/	cron nocturne (02h30)
2	mémoire de Claude	cron
3	suivi (riemann_handoff, sans secrets)	cron
4	fichiers non suivis par git	cron
5	petits fichiers des calculs (moins de 200 Ko)	cron
7	configuration locale (adresses du cluster)	cron
8	fichiers ignorés par git, non secrets	cron
6	secrets, chiffrés par phrase de passe	manuel, à la demande

Le cron de 02h30 ne part que si PC1 est allumé à cette heure.

9. Ce qui reste à vérifier

- Le jeu 6 n'a **jamais été exécuté en réel** : seule sa simulation a été faite.
- La rotation a été testée avec un faux rclone (6 cas : une archive, deux, quatre, simulation, envoi absent, intrus dans le dossier), **jamais sur le vrai Proton**.
- La taille réelle de l'archive chiffrée est inconnue avant le premier envoi.

Mis à jour : 2026-10-04 — 142 lignes